

TLP:CLEAR

INCIDENT REPORT

Credential-harvesting campaign on compromised WordPress sites — brand and own-domain spoofing lures

Credential Phishing • Brand Spoofing • Compromised WordPress • Redirect Abuse • PhaaS

Parameter	Value
Period	6–7 July 2026 (two waves)
Classification	Credential-harvesting phishing
Threat level	MEDIUM
Attribution	Shared phishing kit / PhaaS, low confidence (distinct sending infrastructure per wave)
Target	Corporate mailboxes at a monitored domain (target details withheld)
Status	Analyzed; harvest pages hosted on compromised sites

1. Executive Summary

On 6 and 7 July 2026, corporate mailboxes at a monitored domain received two phishing emails sharing a common set of tactics and, most likely, a common phishing kit (PhaaS). Both waves aim to harvest corporate email credentials: the victim is lured to a link and prompted to enter a username and password on a fake page.

The defining feature of the campaign is that the credential-harvest pages are hosted not on attacker-owned domains but on compromised legitimate WordPress sites (paths of the form /wp-includes/...). The actual phishing link is masked behind a redirect chain (the t.co shortener, the google.com/url open-redirect). Both waves were sent with sender spoofing and an SPF softfail.

The waves originate from different infrastructure (a residential address in Bulgaria and a hosting address in the Netherlands) yet follow an identical execution pattern. This points to a shared phishing kit used by multiple operators rather than a single targeted operation. This report is published so that defenders can block the specific malicious URLs and notify the owners of the compromised sites.

2. Campaign Overview

Two waves were observed one day apart. Both imitate a legitimate notification and carry minimal text in order to move the user quickly to an external credential-entry page.

Feature	Wave 1 (6 Jul)	Wave 2 (7 Jul)
Lure (brand)	American Express KYC	Victim's own-domain administrator
Subject	"Reminder: Your action is needed"	"Unrecognized Login / [9] pending incoming Emails"
Sender (IP)	78[.]130[.]245[.]134	77[.]83[.]39[.]10
Network type	Residential ISP (Bulgaria)	Datacenter / hosting (Netherlands)
Authentication	SPF softfail (spoof)	SPF softfail (spoof)
Link obfuscation	t.co shortener	google.com/url open-redirect
Harvest page	compromised WordPress	compromised WordPress + compromised site

3. Wave 1 — American Express brand impersonation (6 Jul)

The email imitates an American Express verification ("KYC") notice with the subject "Reminder: Your action is needed". It was sent from 78[.]130[.]245[.]134 — a residential connection of a Bulgarian ISP (AbuseIPDB reputation 47, multiple reports). The sender was spoofed as a free webmail service; the SPF check returned softfail, i.e. the address is not authorized to send on behalf of the claimed domain.

The body is padded with legitimate americanexpress.com links (decoys), among which a single working link is hidden — a t.co shortener address. It leads (via redirect) to a credential-harvest page on a compromised WordPress site: hxxps://taylorfoothealth[.]co[.]uk/wp-includes/paymm[.]html. The site itself (a UK clinic) is a bona-fide victim of compromise.

4. Wave 2 — own-domain spoofing (7 Jul)

The second wave imitates a service notice from the recipient's own-domain "administrator": subject "Unrecognized Login" / "[9] pending incoming Emails", with an "Action Required" call. It was sent from 77[.]83[.]39[.]10 — a datacenter address in the Netherlands (AbuseIPDB reputation 100, 393 reports; a known-malicious mailing node). The SPF check likewise returned softfail.

The email carries two credential-harvest links, both on compromised legitimate sites: hxxps://habitatcyprus[.]com/wp-includes/build/ (compromised WordPress) and — via the google.com/url?q=open-redirect — hxxps://lavilifescience[.]com/authn/mail/login[.]html. The second page prefills the victim address via a template token to make the sign-in form more convincing.

4.1. Retrieved payload and kit mechanics

The credential page was retrieved (anonymously) and analyzed. It is a static "Webmail" harvester (not AiTM / reverse-proxy). The page HTML is obfuscated with the document.write(unescape("%XX...")) trick. The form has an email field (read-only, prefilled with the victim address), a password field, and a hidden _gotcha honeypot field.

Credential theft is client-side: JavaScript sends the entered data via fetch POST (JSON) to the legitimate form service Formspark — hxxps://submit-form[.]com/4FJePSjAq. A "double-harvest" is implemented (attempt=first/second): the first submission feigns an error so the victim re-enters the password, filtering out typos. After theft the user is redirected to hxxps://<their-email-domain> so the visit appears to complete normally. The kit files are served by a small PHP framework (routes.php, pages.php, registry.php) that was exposed via an open directory listing.

Sophistication is low (a commodity kit abusing a public SaaS for exfiltration instead of dedicated infrastructure). The Formspark exfil channel (form ID 4FJePSjAq) is the priority take-down target: disabling it severs delivery of the stolen credentials.

5. Assessment and shared tactics

Despite different lure brands and different sending infrastructure, both waves follow the same pattern, pointing to a shared phishing kit:

- Sender spoofing (a brand, or the victim's own domain) with an SPF softfail.
- Credential-harvest pages hosted on compromised legitimate WordPress sites (/wp-includes/... paths) rather than attacker domains — this frustrates domain-level blocking and extends the infrastructure's lifetime.
- Obfuscation of the payload link via trusted redirects (t.co, google.com/url) to evade reputation filtering.
- Different sending nodes per wave (residential BG, datacenter NL) — a sign of several operators of one kit (PhaaS) rather than a single targeted operation.

Important: the domains of these pages (taylorfoothealth[.]co[.]uk, habitatcyprus[.]com, lavilifescience[.]com) belong to bona-fide organizations and are themselves victims of compromise. Defenders should block the specific malicious URLs, not the whole domains, and where possible notify the site owners.

6. Indicators of Compromise (IOCs)

Values are shown defanged. Production-ready values are in the machine-readable STIX 2.1 / MISP dumps.

Type	Value	Context
IP (src)	78[.]130[.]245[.]134	Coolbox AD, Bulgaria, residential; AbuseIPDB 47. Sender of wave 1.
IP (src)	77[.]83[.]39[.]10	Lanedonet/Pitline Ltd, Netherlands, datacenter; AbuseIPDB 100. Sender of wave 2.
URL	hxxps://taylorfoothealth[.]co[.]uk/wp-includes/paymm[.]html	Credential-harvest page (compromised WordPress).
URL	hxxps://habitatcyprus[.]com/wp-includes/build/	Credential-harvest page (compromised WordPress).
URL	hxxps://lavilifescience[.]com/authn/mail/login[.]html	Credential-harvest page (compromised site).
URL (exfil)	hxxps://submit-form[.]com/4FJePSjAq	Formspark: credential exfiltration endpoint (kit POSTs stolen JSON here). Take-down target.
Redirect	hxxps://t[.]co/W8S9YV2vYD	Link obfuscation (shortener); do not block t.co as a whole.
Redirect	google[.]com/url?q=	Open-redirect used to mask the payload link.

6.1. MITRE ATT&CK

- T1566.002 — Phishing: Spearphishing Link
- T1656 — Impersonation
- T1584.004 — Compromise Infrastructure: Server

7. Recommendations

- Block the listed malicious URLs and sending IPs at the mail gateway and proxy.
- Block specific URLs rather than the domains of compromised sites; notify the site owners of the compromise (/wp-includes/... paths).
- Enforce SPF/DKIM/DMARC alignment checks; flag mail from your own domain that arrives externally and fails authentication.
- Train users to recognize "unrecognized login" / "pending emails" lures and not to enter credentials via links in email; deploy phishing-resistant FIDO2/MFA.
- Monitor redirects through trusted services (t.co, google.com/url) as a possible reputation-filter bypass.

TLP:CLEAR — This document may be distributed without restriction.